

Informe de Seguridad - OWASP ZAP

Información del Escaneo

Objetivo:	http://localhost:8501
Herramienta:	OWASP ZAP 2.16.1
Tipo de escaneo:	Quick Scan (Spider + Active Scan)
Fecha:	16/04/2026
Proyecto:	Dashboard ETalent - ESPOCH
Responsable:	Jefferson Jordan

Resumen de Alertas

Nivel de Riesgo	N° de Alertas
Alto	0
Medio	1
Bajo	3
Informativo	2

Detalle de Alertas

[MEDIO]	Cabecera Content Security Policy (CSP) no configurada
ID ZAP:	10038
Instancias:	3
Descripcion:	Falta el encabezado HTTP 'Content-Security-Policy' en las respuestas del servidor. Sin esta politica, el navegador no tiene restricciones sobre que recursos puede cargar, facilitando ataques Cross-Site Scripting (XSS) e inyeccion de datos.
Solucion:	Configurar un reverse proxy (Nginx/Apache) delante de Streamlit y agregar: add_header Content-Security-Policy "default-src 'self'; script-src 'self' 'unsafe-inline';";
Referencia:	OWASP Top 10 A05:2021 - Security Misconfiguration

[BAJO]	Divulgacion de Marcas de Tiempo (Unix Timestamp)
ID ZAP:	10096
Instancias:	2
Descripcion:	El servidor expone timestamps en formato Unix en algunas respuestas HTTP. Esto puede revelar informacion sobre la infraestructura y facilitar ataques de reconocimiento.
Solucion:	Filtrar o eliminar cabeceras que expongan timestamps internos desde el proxy.
Referencia:	CWE-200: Exposure of Sensitive Information

[BAJO]	Filtracion de version en cabecera 'Server'
ID ZAP:	10036
Instancias:	39
Descripcion:	El encabezado HTTP 'Server' revela la version exacta del stack (Python/Tornado). Esta informacion permite a atacantes buscar exploits conocidos para esa version especifica.
Solucion:	En Nginx: server_tokens off;

Informe de Seguridad - OWASP ZAP

	En Apache: ServerTokens Prod; ServerSignature Off;
Referencia:	CWE-200 / OWASP A05:2021

[BAJO]	Falta encabezado X-Content-Type-Options
ID ZAP:	10021
Instancias:	46
Descripcion:	Ausencia del encabezado 'X-Content-Type-Options: nosniff'. Sin el, el navegador puede realizar MIME-type sniffing e interpretar archivos con tipo incorrecto, habilitando posibles ataques de ejecucion de contenido.
Solucion:	Agregar en el proxy: add_header X-Content-Type-Options "nosniff" always;
Referencia:	OWASP Top 10 A05:2021

[INFORMATIVO]	Aplicacion Web Moderna (SPA detectada)
ID ZAP:	10109
Instancias:	3
Descripcion:	ZAP detecto que la aplicacion es una Single Page Application (SPA) basada en React/Streamlit. El spider tradicional tiene cobertura limitada en SPAs. No es una vulnerabilidad.
Solucion:	Considerar usar el spider AJAX de ZAP para mayor cobertura en futuros escaneos.
Referencia:	N/A

[INFORMATIVO]	Comentarios sospechosos en codigo JavaScript
ID ZAP:	10027
Instancias:	4
Descripcion:	Se encontraron comentarios en el JavaScript del frontend (generados por Streamlit/React) que contienen palabras como TODO, FIXME o debug. No representan vulnerabilidad directa pero revelan informacion sobre el proceso de desarrollo.
Solucion:	Minificar y ofuscar el JavaScript en produccion. En Streamlit esto ocurre automaticamente al desplegar.
Referencia:	CWE-615: Inclusion of Sensitive Information in Source Code Comments

Conclusiones y Recomendaciones

El escaneo no detecto vulnerabilidades de nivel Alto. Las 4 alertas accionables (1 media, 3 bajas) estan relacionadas con cabeceras HTTP de seguridad ausentes, un problema comun en aplicaciones Streamlit que no utilizan un reverse proxy.

Accion prioritaria: antes del despliegue en infraestructura ESPOCH, configurar Nginx como reverse proxy con las cabeceras: Content-Security-Policy, X-Content-Type-Options, y suprimir la version en el encabezado Server. Estas 3 correcciones eliminan el 100% de las alertas accionables encontradas.